

Board readout

Comprehensive target-state design · Kestrel Industrial Supply (Pty) Ltd

Named reviewer: Named review lead

Decision context

Action accepted by management and scheduled: define and implement red-flag monitoring for vendor master data changes, depot stock adjustments and payroll master changes, with a first coverage report to the Audit and Committee.

The recorded result needs bounded reliance

The deterministic readiness result remains unchanged by narrative. The supplied information defines the boundary within which management can use the recorded position.

Deterministic readiness 55 / 100 · Developing	Exposure Not scored	Review notes in scope 1 of 64 items	Open information 63 items requiring action
--	-------------------------------	--	---

Board reading: treat the score as the recorded assessment result; treat review notes as bounded to the named information scope.

What is recorded and what remains open

Review notes in scope

No bounded review note is attached to the priority findings.

Open information

Monitoring output for recent periods

The 2026 incident register records six incidents across four sites with categories, values, reporting channel, owner and closure dates, and shows two matters still under investigation. It evidences that incidents are captured and worked, but it is a reactive record: it does not demonstrate periodic monitoring output over a defined transaction population, and no run date, population scope or coverage percentage is present. Two of the six entries originate from analytics or internal audit, which indicates some proactive detection, but the register alone cannot establish that monitoring operates on a defined cycle. further basis required to support the detection-monitoring assertion. Linked to the detection, its underlying and the associated control-effectiveness.

Plausible pathways show how exposure may develop

The scenarios below are plausible, organisation-specific pathways linked to the recorded control and exposure universe. They are not allegations.

Without deliberate monitoring, fraud is found only by accident, complaint or external notification, typically long after the loss has compounded

Entry point: The recorded control condition is engaged through Fraud Detection Capability: The organisation monitors transactions or operational activity for unusual patterns, anomalies or red flags. · Mechanism: Misuse can occur when an actor exploits the recorded control condition and without deliberate monitoring, fraud is found only by accident, complaint or external notification, typically long after the loss has compounded.

Control bypassed: Defined monitoring covers the material transaction and activity population, uses risk-based indicators, and produces reviewable output on a set rhythm rather than relying on incidental discovery. · Concealment: The activity may appear routine until complete population review, independent approval or exception monitoring exposes it. · Consequence: Direct -- unreviewed exceptions can allow losses to compound.; Alert backlogs can conceal important anomalies. · Warning: A material process unmonitored, or a monitoring cycle missed without escalation.; An exception, access, approval or incident record that cannot be reconciled to the complete in-scope population. · Immediate containment: Escalate to CFO / COO, preserve relevant records and apply the control's escalation threshold: A material process unmonitored, or a monitoring cycle missed without escalation. · Long-term response: The monitoring owner must define red-flag indicators per material process — duplicate payments, round-value patterns, out-of-hours activity, unusual volume by user, adjustments reversing prior entries, and supplier or customer concentration — run them against the complete transaction population on a set rhythm, and route output into the exception queue with named reviewers and SLAs; coverage against the process fraud maps is reported to the fraud forum.

Controls decay quietly through staff turnover, system change and workload pressure, so a control believed to be operating may have lapsed months earlier

Entry point: The recorded control condition is engaged through Continuous Improvement and Fraud Monitoring: The organisation periodically reviews its fraud risks and control environment. · Mechanism: Misuse can occur when an actor exploits the recorded control condition and controls decay quietly through staff turnover, system change and workload pressure, so a control believed to be operating may have lapsed months earlier.

Control bypassed: A scheduled review reassesses fraud risks, tests whether key controls still operate as designed, and reports a consolidated position with owned actions to governance. · Concealment:

The activity may appear routine until complete population review, independent approval or exception monitoring exposes it. · Consequence: Impact requires case-specific validation.; Operating impact requires case-specific validation. · Warning: An exception, access, approval or incident record that cannot be reconciled to the complete in-scope population · Review overdue, or a key control found

Leadership choices define ownership and trade-offs

Approve accountable executive mandates and escalation authority for priority remediation.

Hard-gate, governance and maturity-limiting controls require authority to allocate resources and resolve blockers.

OPTIONS · OPTION A - RETAIN ACCOUNTABILITY WITH THE FINANCE DIRECTOR (REJECTED: DESIGN AND ADJUDICATION WOULD SIT WITH ONE EXECUTIVE); OPTION B - DELEGATE DETECTION DESIGN TO THE FINANCIAL CONTROLLER WITH QUARTERLY AUDIT AND COMMITTEE REPORTING (RECOMMENDED AND ACCEPTED); OPTION C - OUTSOURCE MONITORING TO AN EXTERNAL PROVIDER (REJECTED AT CURRENT MATURITY: KESTREL CANNOT YET SPECIFY THE INDICATOR SET IT NEEDS)

OPTION ANALYSIS · OPTION A — OPTION A - RETAIN ACCOUNTABILITY WITH THE FINANCE DIRECTOR (REJECTED: DESIGN AND ADJUDICATION WOULD SIT WITH ONE EXECUTIVE); COST/EFFORT: COST AND EFFORT REQUIRE MANAGEMENT CONFIRMATION BEFORE APPROVAL.; BENEFIT: BUILDS DURABLE OWNERSHIP INSIDE THE ORGANISATION.; TRADE-OFF: USES INTERNAL CAPACITY AND MAY MOVE MORE SLOWLY WHERE CAPABILITY IS IMMATURE.; REJECTION REASON: REJECTED: DESIGN AND ADJUDICATION WOULD SIT WITH ONE EXECUTIVE | OPTION B — OPTION B - DELEGATE DETECTION DESIGN TO THE FINANCIAL CONTROLLER WITH QUARTERLY AUDIT AND COMMITTEE REPORTING (RECOMMENDED AND ACCEPTED); COST/EFFORT: COST AND EFFORT REQUIRE MANAGEMENT CONFIRMATION BEFORE APPROVAL.; BENEFIT: ADDS FOCUSED SPECIALIST CAPACITY AGAINST THE NAMED PRIORITY.; TRADE-OFF: INTRODUCES EXTERNAL COST, HANDOVER EFFORT AND A DEPENDENCY ON CLEAR SCOPE.; RECOMMENDED OPTION | OPTION C — OPTION C - OUTSOURCE MONITORING TO AN EXTERNAL PROVIDER (REJECTED AT CURRENT MATURITY: KESTREL CANNOT YET SPECIFY THE INDICATOR SET IT NEEDS); COST/EFFORT: COST AND EFFORT REQUIRE MANAGEMENT CONFIRMATION BEFORE APPROVAL.; BENEFIT: COMBINES INTERNAL ACCOUNTABILITY WITH TARGETED SPECIALIST SUPPORT.; TRADE-OFF: NEEDS EXPLICIT BOUNDARIES SO OWNERSHIP AND ESCALATION ARE NOT DILUTED.; REJECTION REASON: REJECTED AT CURRENT MATURITY: KESTREL CANNOT YET SPECIFY THE INDICATOR SET IT NEEDS

MK RECOMMENDATION · VIABLE OPTIONS CONSIDERED. OPTION A - LEAVE ACCOUNTABILITY WITH THE FINANCE DIRECTOR AS THE POLICY CURRENTLY STATES. TRADE-OFF: PRESERVES THE APPROVED POLICY AND NEEDS NO CHANGE CONTROL, BUT THE FINANCE DIRECTOR IS ALREADY THE ESCALATION ROUTE FOR REPORTED INCIDENTS, SO THE SAME EXECUTIVE WOULD OWN BOTH DETECTION DESIGN AND INCIDENT ADJUDICATION, WHICH WEAKENS INDEPENDENCE. OPTION B - DELEGATE DETECTION DESIGN TO THE FINANCIAL CONTROLLER WITH QUARTERLY COMMITTEE REPORTING. TRADE-OFF: SEPARATES DESIGN FROM ADJUDICATION AND USES AN EXISTING BUDGETED WORKSTREAM; REQUIRES A MINOR POLICY AMENDMENT AT THE NEXT REVIEW. OPTION C - OUTSOURCE MONITORING TO AN EXTERNAL PROVIDER. TRADE-OFF: FASTEST ROUTE TO COVERAGE, BUT AT THIS MATURITY KESTREL CANNOT YET SPECIFY WHAT IT WANTS MONITORED, SO THE PROVIDER WOULD DEFINE THE INDICATORS AND THE ORGANISATION WOULD NOT OWN THEM. MANAGEMENT OPTION B ACCEPTED BY THE FINANCE DIRECTOR ON REVIEW. OWNER: FINANCIAL CONTROLLER. DATE: 30 NOVEMBER 2026 FOR THE FIRST QUARTERLY REPORT TO THE COMMITTEE.

RECOMMENDATION RATIONALE · THE RECOMMENDATION FOLLOWS THE LINKED DETERMINISTIC AND PRIORITIES; MANAGEMENT MUST CONFIRM THE FINAL ROUTE, COST AND DELIVERY CAPACITY.

MANAGEMENT / BOARD DECISION · MANAGEMENT TO CONFIRM THE SELECTED OPTION, ACCOUNTABLE OWNER AND DATE.

DECISION OWNER

CEO / Managing Director

DECISION DEADLINE · 30 DAYS

Choose and record remediation rather than passive acceptance for Critical and High risks.

Plausible consequence pathways require an explicit leadership treatment.

OPTIONS · OPTION A — DELIVER THROUGH EXISTING INTERNAL OWNERSHIP; OPTION B — USE BOUNDED SPECIALIST SUPPORT; OPTION C — COMBINE INTERNAL OWNERSHIP WITH TARGETED SPECIALIST SUPPORT

OPTION ANALYSIS · OPTION A — OPTION A - DELIVER THROUGH EXISTING INTERNAL OWNERSHIP; COST/EFFORT: COST AND EFFORT REQUIRE MANAGEMENT CONFIRMATION BEFORE APPROVAL.; BENEFIT: BUILDS DURABLE OWNERSHIP INSIDE THE ORGANISATION.; TRADE-OFF: USES

DECISION OWNER

CEO / Managing Director

DECISION DEADLINE · 30 DAYS

Sequenced action builds a repeatable control cycle

30 days

Apply immediate escalation at "Any assurance reviewer assigned operational ownership of the control under review." and deliver the exact control design: The CEO and audit-committee chair must approve a RACI that assigns control operation to management and owners, reserves independent testing and unrestricted reporting for internal audit or equivalent assurance, and requires annual conflict review; the company secretary retains the approved RACI and minutes.

CEO / Managing Director ·
Approved fraud- RACI;
Audit-committee minutes
showing independent
reporting; Internal audit
charter or assurance
mandate

Apply immediate escalation at "A qualifying matter escalated late, or an escalation routed only through an implicated manager." and deliver the exact control design. The Head of must publish escalation criteria

60 days

Apply immediate escalation at "Any unexplained custody gap, integrity mismatch or unauthorised repository access." and deliver the exact control design: The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.

General Counsel / COO ·
Chain-of-custody forms;
Evidence register; Hash or
seal records; Repository
access log; Retention/legal-
hold instruction

Apply immediate escalation at "Any unknown or unjustified privileged account, missed recertification or leaver access beyond 24 hours" and deliver the exact control design: IT Security

90 days

Apply immediate escalation at "A material process unmonitored, or a monitoring cycle missed without escalation." and deliver the exact control design: The monitoring owner must define red-flag indicators per material process — duplicate payments, round-value patterns, out-of-hours activity, unusual volume by user, adjustments reversing prior entries, and supplier or customer concentration — run them against the complete transaction population on a set rhythm, and route output into the exception queue with named reviewers and SLAs; coverage against the process fraud maps is reported to the fraud forum.

CFO / COO · Coverage report against process fraud maps; Monitoring output for recent periods; Population reconciliation to source systems; Red-flag indicator definitions per process

Apply immediate

The board should track ownership, information and ageing

Information coverage

Supplied records and open information items within the named scope.

Open information

Count and age of recorded or further-basis items.

Action ageing

Open, blocked and overdue management actions by owner.

Risk movement

Priority risk changes, accepted residual risk and scenario indicators.

NEXT BOARD CHECKPOINT

Set the next checkpoint date and require the annotated register as the supporting pack.

Control completeness: What (objective); Who (accountable executive); Population (complete in-scope population); Frequency (operating cycle); Evidence retained; Independent check; Escalation trigger / recipient; SLA; Effectiveness measure; Failure response.

This readout is bounded by the named scope and is not a legal, forensic or certification conclusion.